

**UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA
INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE
FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE**

- 1. PURPOSE:** The purpose of this notice is to amend the Department of Veterans Affairs (VA) Handbook 6500.6, Contract Security, to include updated security language for Appendix C.
- 2. POLICY:**
 - a. The Office of Information Security published VA Handbook 6500.6, Contract Security on March 12, 2010. This handbook is currently under revision and will incorporate many updates and changes but must go through departmental concurrence prior to publication.
 - b. This notice replaces VA Handbook 6500.6, Appendix C, VA Information and Information System Security/Privacy Language for Inclusion into Contracts, as appropriate, to incorporate updated security language.
 - c. This change will take place immediately and should be applied to the current version of VA Handbook 6500.6 Appendix C.
- 3. RESPONSIBLE OFFICE:** Office of Information and Technology (OIT) (005); Office of Information Security (005R).
- 4. RELATED HANDBOOK:** [VA Handbook 6500.6, Contract Security, dated March 12, 2010.](#)
- 5. RESCISSION:** This notice will be rescinded and guidance incorporated into the appropriate directive/handbook no later than one year after the date of publication.

CERTIFIED BY:

**BY DIRECTION OF THE SECRETARY
OF VETERANS AFFAIRS:**

/s/
Guy T. Kiyokawa
Assistant Secretary for
Enterprise Integration

/s/
Kurt D. DelBene
Assistant Secretary for
Information and Technology and
Chief Information Officer

DISTRIBUTION: Electronic Only

APPENDIX C — VA INFORMATION AND INFORMATION SYSTEM SECURITY AND PRIVACY LANGUAGE FOR INCLUSION IN CONTRACTS, AS APPROPRIATE

NOTE: Any sections (1-14) which DO NOT apply should not be included in the Statement of Work (SOW), Performance Work Statement (PWS), Product Description (PD) or contract.

- 1. GENERAL.** This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.
- 2. VA INFORMATION CUSTODIAL LANGUAGE.** This entire section applies to all acquisitions requiring any Information Security and Privacy language.
 - a. The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 *Rights in Data – General*. The primary clause used to define computer software license (not data/intellectual property first produced under this contract or order) is FAR 52.227-19, *Commercial Computer Software License*.
- 3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS.** This section applies when any person requires access to information made available to the contractor by VA for the performance or administration of this contract or information developed by the contractor in performance or administration of the contract.
 - a. A contractor/subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees and subcontractors only to the extent necessary to perform the services specified in the solicitation or contract. This includes indirect entities, both affiliate of contractor/subcontractor and agent of contractor/subcontractor.
 - b. All contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All contractors and subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the contractor must state where all non-U.S. services are provided. The contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted.
 - c. The contractor shall notify the COR/CO in writing immediately (no later than 24

APPENDIX C

hours) after personnel separation or occurrence of other causes. Causes may include the following:

- (1) Contractor/subcontractor personnel no longer has a need for access to VA information or VA information systems.

Contractor/subcontractor personnel are terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.

- (2) Contractor believes their own personnel or subcontractor personnel may pose a threat to their company's working environment or to any company-owned property. This includes contractor-owned assets, buildings, confidential data, customers, employees, networks, systems, trade secrets and/or VA data.
- (3) Any previously undisclosed changes to contractor/subcontractor background history are brought to light, including but not limited to changes to background investigation or employee record.
- (4) Contractor/subcontractor personnel have their authorization to work in the United States revoked.
- (5) Agreement by which contractor provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and/or physical access for contractor personnel.

4. **TRAINING. Not Applicable**

5. **SECURITY INCIDENT INVESTIGATION.** This entire section applies to all acquisitions requiring any Information Security and Privacy language.

- a. The contractor, subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the contractor, subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- b. To the extent known by the contractor/subcontractor, the contractor/subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).
 - (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).

APPENDIX C

- (5) The amount of data belonging to VA believed to have been compromised.
- (6) The remediation measures the contractor is taking to ensure no future incidents of a similar nature.
- c. After the contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The contractor, subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- d. VA IT contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.
- e. In instances of theft or break-in or other criminal activity, the contractor/subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The contractor, its employees, and its subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The contractor/subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.
- f. The contractor shall comply with VA Handbook 6500.2, *Management of Breaches Involving Sensitive Personal Information*, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
- g. With respect to unsecured Protected Health Information (PHI), the contractor is deemed to have discovered a data breach when the contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
- h. If the contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach involving any VA sensitive personal information the contractor/subcontractor processes or maintains under the contract; the contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT. Not Applicable**7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE.**

APPENDIX C

This entire section applies to information systems, systems, major applications, minor applications, enclaves, and platform information technologies (cloud and non-cloud) hosted, operated, maintained, or used on behalf of VA at non-VA facilities.

- a. VA prohibits the installation and use of personally owned or contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall on the non-VA owned OE. Approved contractor OE will be subject to technical inspection at any time.

8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING. Not Applicable

9. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING. This entire section applies when the acquisition involves any product (application, hardware, or software) or when section 6 or 7 is included.

- a. The contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- b. When contracting terms require the contractor to procure equipment, the contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The contractor shall attest that equipment procured from an OEM or authorized reseller or distributor are authentic. If procurement is unavailable from an OEM or authorized reseller, the contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.
- c. All contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation will include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The contractor shall make spare parts available. All contractor(s) shall specify how digital delivery for procured products, including patches, will be validated and monitored to

APPENDIX C

ensure consistent delivery. The contractor shall apply encryption technology to protect procured products throughout the delivery process.

- d. If a contractor provides software or patches to VA, the contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- e. The contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the data formats defined in the National Telecommunications and Information Administration (NTIA) report "The Minimum Elements for a Software Bill of Materials (SBOM)."
- f. Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- g. Throughout the delivery process, the contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- h. The contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.